

Network Security

Theory Class Nº8

Jorge Sa Silva
sasilva@deec.uc.pt
University of Coimbra
Portugal

Outline

- Cryptography
  - Darkweb/Deepweeb
  - Block chain



Cryptography

- **Perspective**
  - User
  - Manager
  - Developer
- **Security:** type of attacks
- **Ingredients**
  - Requirements:
    - Data integrity
    - User authentication
    - Confidentiality
  - Kerckhoff's principle
  - Random and pseudo-random generators
  - Symmetric Encryption
  - Asymmetric Encryption
  - Hash
  - Diffie-Hellman
  - Message Authentication Code (MAC)
  - RSA
  - Digital certificates
  - …

- **Applications**
  - Digital signatures
  - TLS
  - Darkweb
  - Blockchain
  - Firewall
  - VPNs
  - …

Darkweb

Definitions

- World Wide Web / Surface Web /Clear Net
- Deep Web
- Dark Web

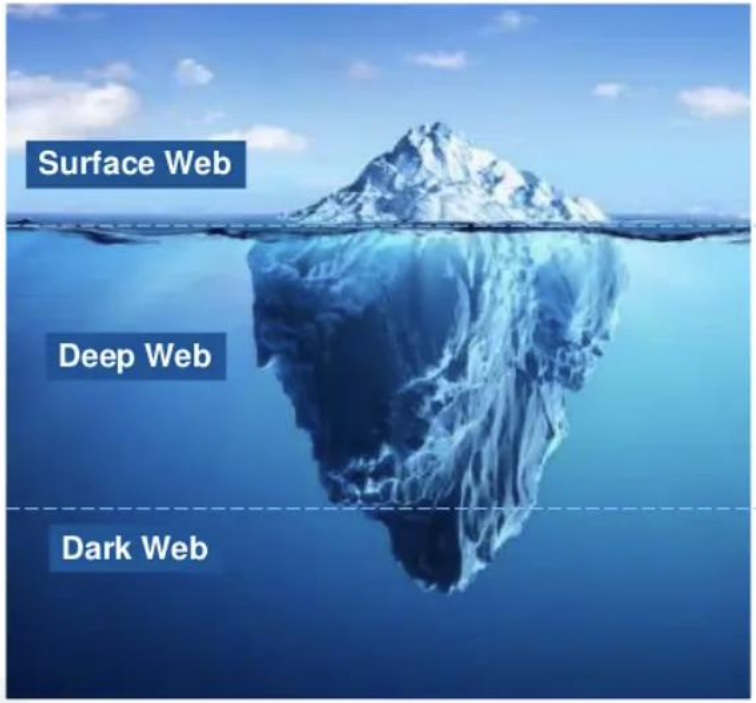


- The same infrastructure: TCP/IP
- Application Layer

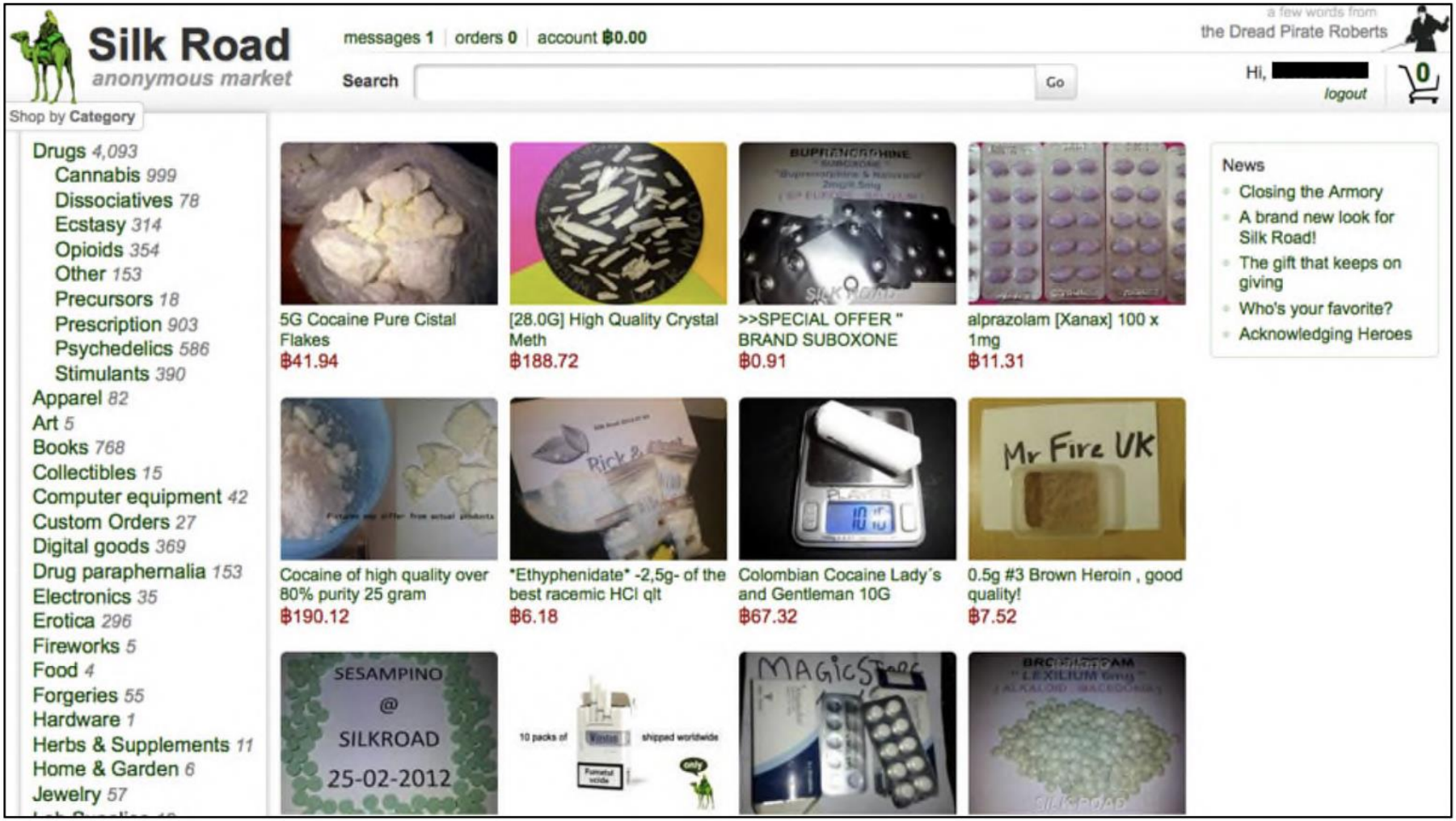
Anonimity


Surface Web
Exploring
The Hidden
Internet
4%
Deep Web
90%
Legal Documents
Government Records
Scientific Reports
Academic Records
Financial Records
Dark Web
6%
Drugs
Tor
Illegal Info

“The iceberg”



Google
amazon
ebay
YouTube
WIKIPEDIA
The Free Encyclopedia
PayPal
Bank of America
HSBC
Dropbox
Silk Road
anonymous marketplace
WikiLeaks
Wall Market



*http://www.thehiddenwiki.net/purchasing-on-silk-road-a-trip-report/

Definitions

TOR

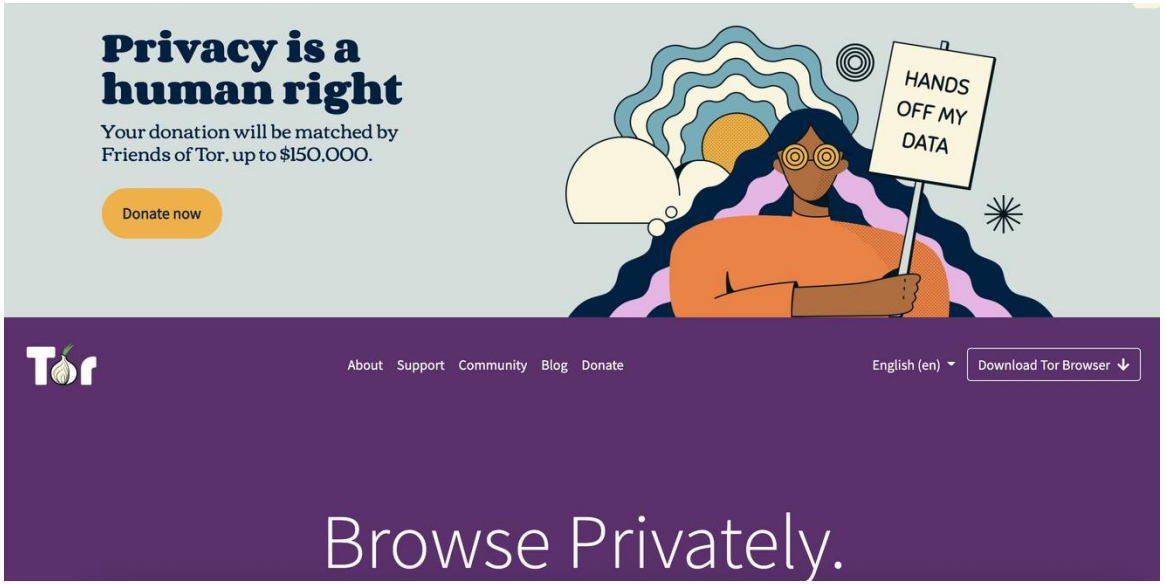
- Short for “The Onion Router” (TOR);
- The most famous anonymous network, which can be accessed using the TOR browser;
- TOR browser allows users to surf the dark web anonymously by directing traffic through a network of intermediaries (adding layers).

Timeline of the Deep Web

- 2002 – Tor Network developed by US Naval Research Laboratory
- 2003 – The I2P peer-to-peer network developed
- 2006 – Tor becomes a non-profit organization
- 2009 – “Satoshi Nakamoto” started Bitcoin digital currency
- 2011 – Silk Road Market launches
- 2012 – Experts estimate earnings of $22M for SR
- 2013 – Silk Road shut down (earnings > $1B)
- 2014 – Other dark web markets proliferate (Agora, Evolution)
- 2015 – Ross Ulbricht sentenced to life; Evolution exit scam

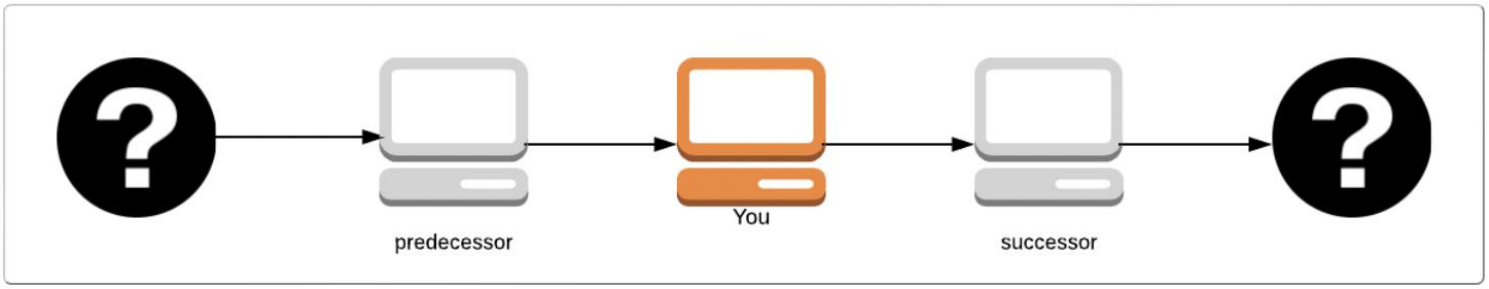
Tor

- https://www.torproject.org/
- Tor Browser
- Tor Net (Onion)



Tor

- Onion Routing is a distributed overlay network designed to anonymise TCP-based applications
- Clients choose a *path *through the network and build a *circuit* where each onion router in the path knows the predecessor and the successor, but no other nodes in the circuit.
- No one knows what data is being sent until it reaches the last node in the path; who knows the data but doesn't know who sent it. The second to last node in the path doesn't know what the data is, only the last node in the path does.



Tor Relays

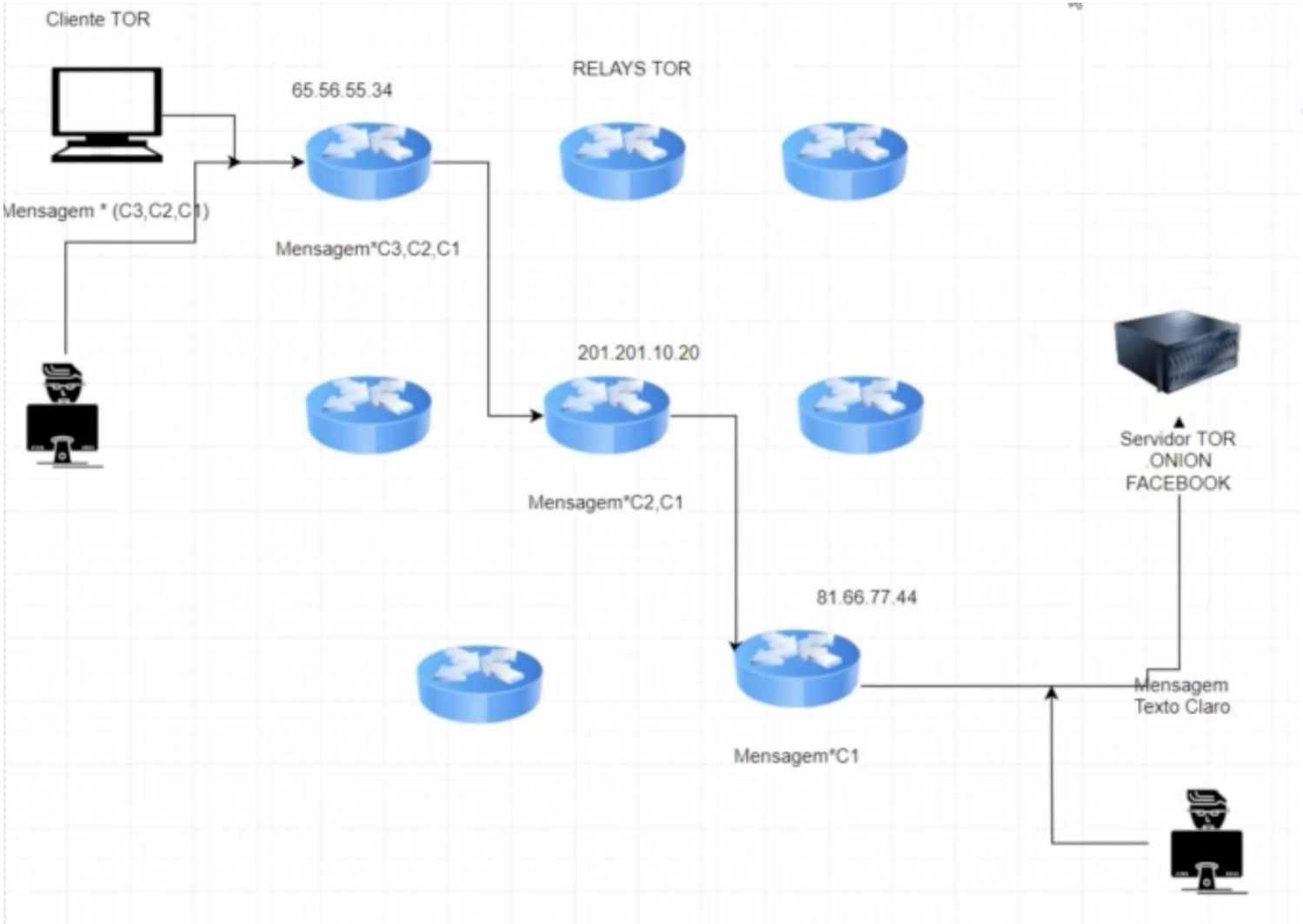
- They are Routers /Crossing points (ponto de passagem)
- Type
  - Middle Relays (public)
  - Exit Relay (final)
  - Bridges (hidden)

Installing

- Tor Browser
  - Firefox
  - Java

How to attack Tor?

- Large organisations with expansive resources run servers to attempt to be the first and last nodes in the network.
- If the organisation's server is the first node, it knows who sent the message.
- If the organisation server is the last node, it knows the final destination and what the message says.

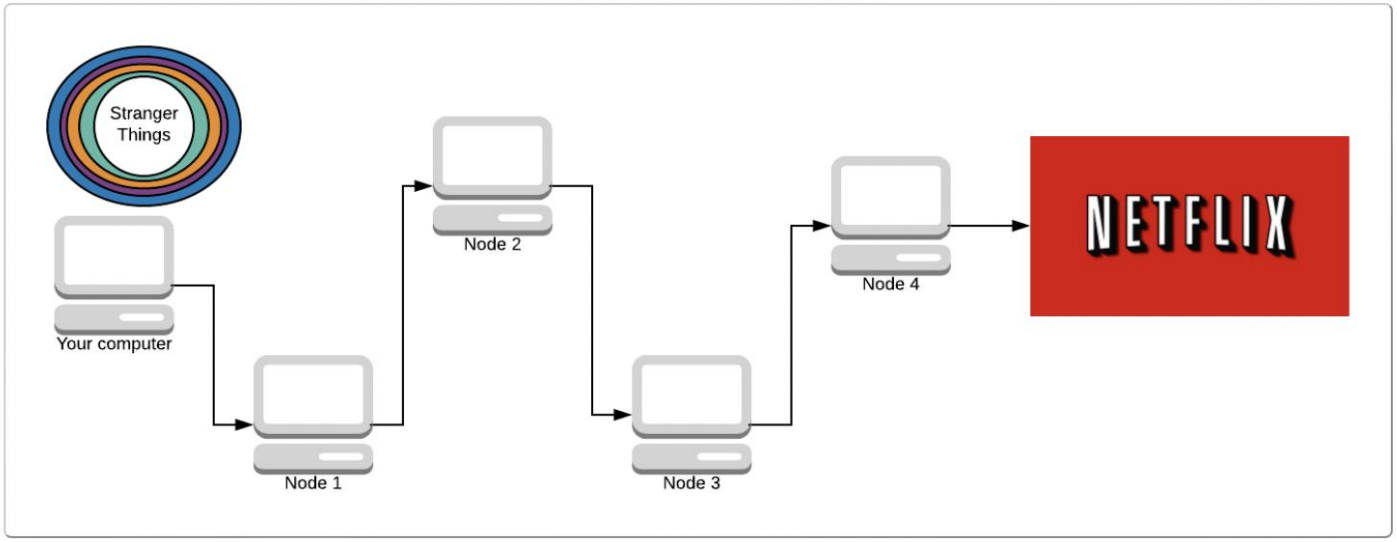

Cliente TOR
RELAYS TOR
65.56.55.34
Mensagem * (C3,C2,C1)
Mensagem*C3,C2,C1
201.201.10.20
Mensagem*C2,C1
Servidor TOR
ONION
FACEBOOK
81.66.77.44
Mensagem
Texto Claro
Mensagem*C1

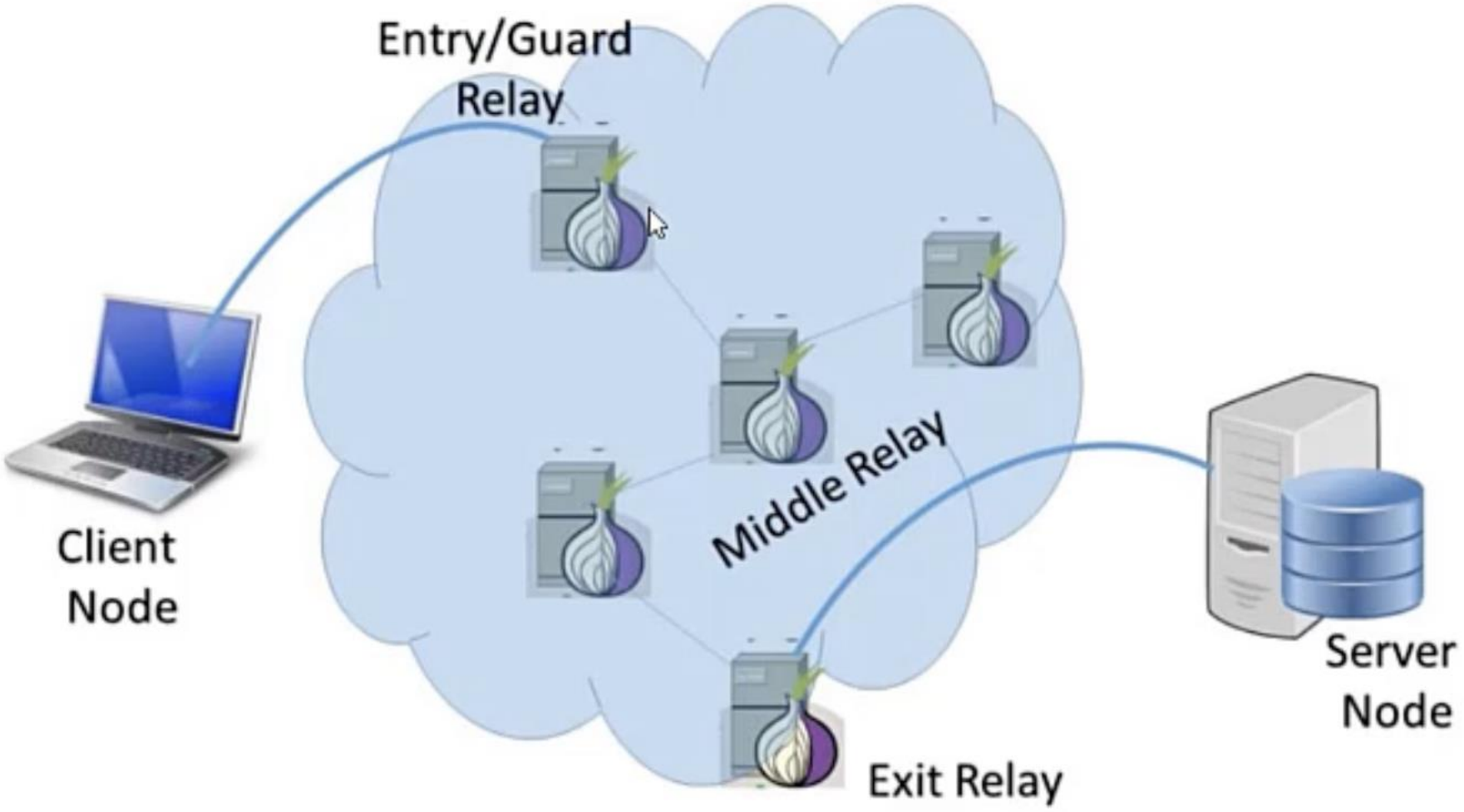
Tor

- Each packet flows down the network in *fixed-size cells*. These cells have to be the same size so none of the data going through the Tor network looks suspiciously big.
- These cells are unwrapped by a **symmetric key** at each router and then the cell is relayed further down the path.
- Tor needs a lot of users to create anonymity, if Tor was hard to use new users wouldn't adopt it so quickly. Because new users won't adopt it, Tor becomes less anonymous. By this reasoning it is easy to see that usability isn't just a design choice of Tor but a *security requirement* to make Tor more secure.

Tor

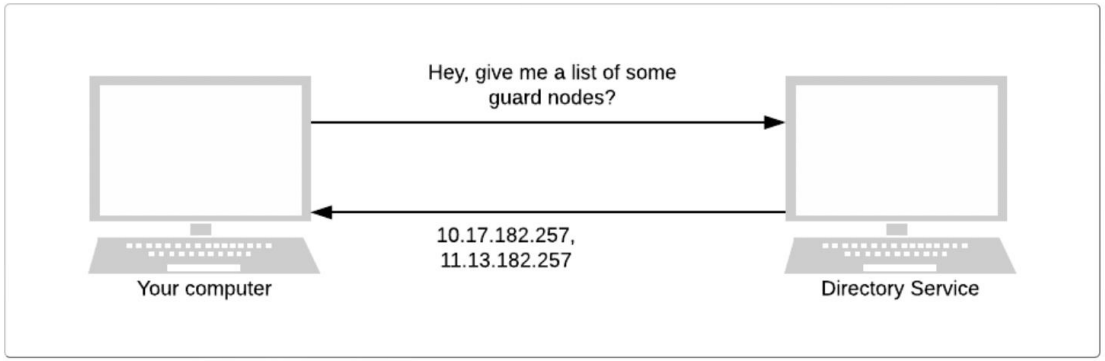
- **Symmetric keys between neighbor nodes**
- The encryption used is normally AES with the key being shared via Diffie-Hellman.

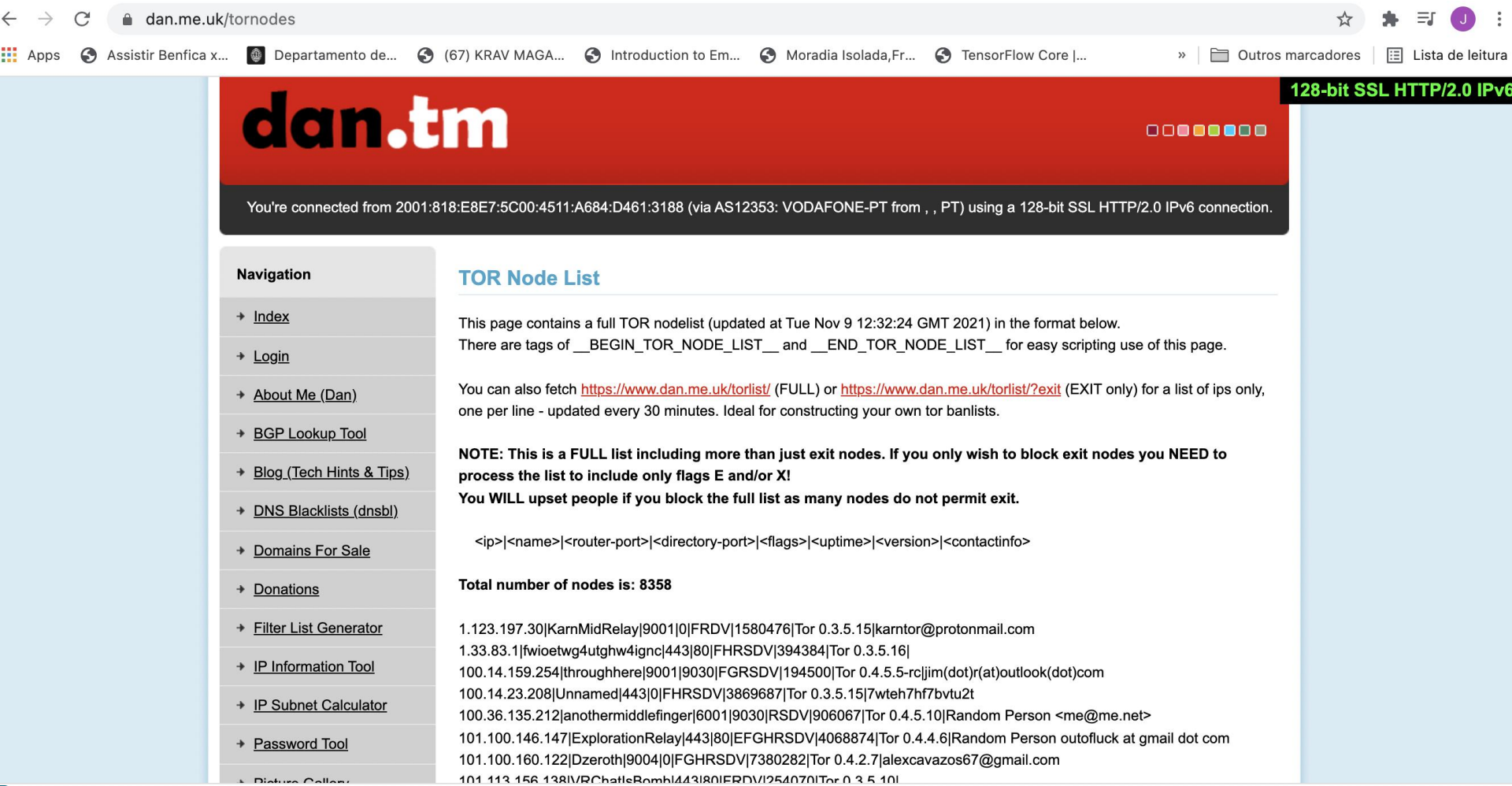



Entry/Guard
Relay
Middle Relay
Client
Node
Server
Node
Exit Relay

Directory Node

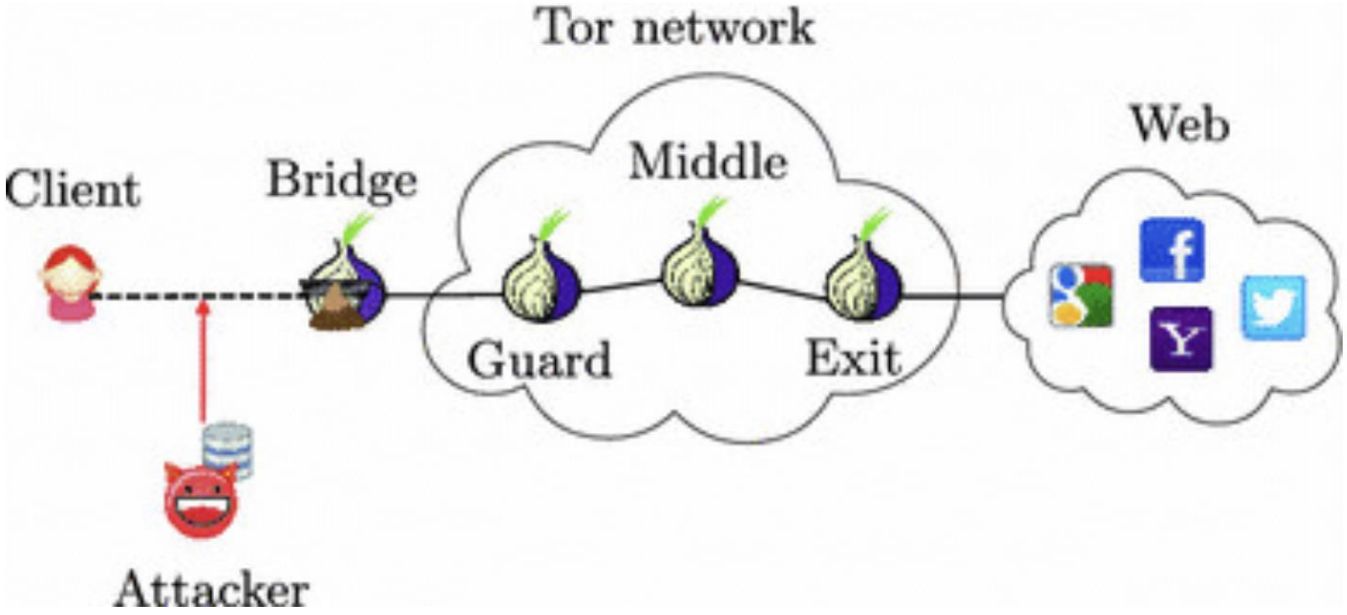
- The state of the Tor network is tracked and publicised by a group of 9 trusted servers (as of 2019) known as *directory nodes*. Each of which is controlled by a different organisation.
- Directory nodes maintain a list of currently running relays (publicly listed node in the Tor network). Once per hour directory nodes publish a consensus together. The consensus is a single document compiled and voted on by each directory node.
- When a Tor user (a client or a node) wants to know the current state of the network, it asks a directory node. -> Potential Problem
- Instead of asking a single directory node for its opinion, clients asks every directory node and combined their opinions into a consensus.



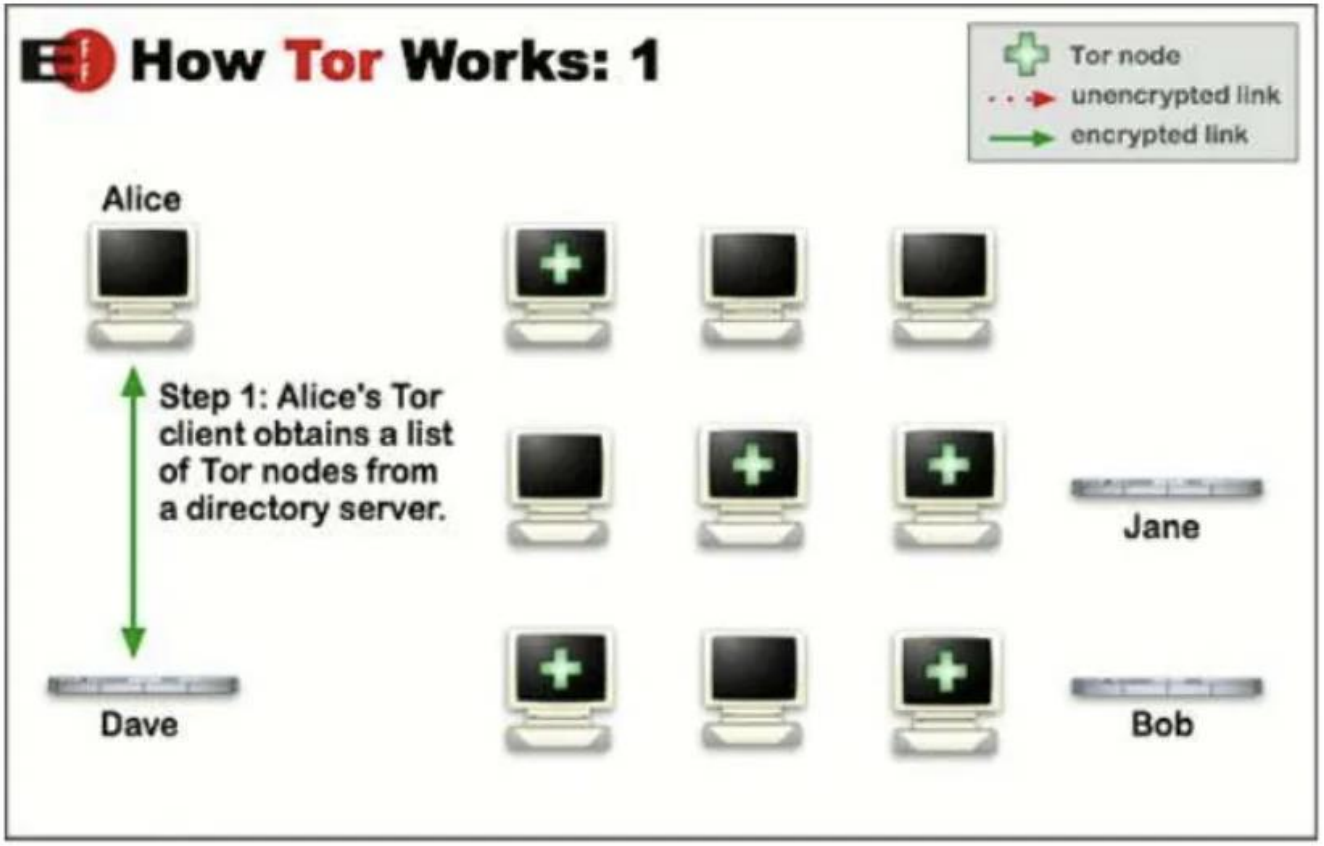

dan.me.uk/tornodes
Apps
Assistir Benfica x...
Departamento de...
(67) KRAV MAGA...
Introduction to Em...
Moradia Isolada,Fr...
TensorFlow Core |...
Outros marcadores
Lista de leitura
dan.tm
128-bit SSL HTTP/2.0 IPv6
You're connected from 2001:818:E8E7:5C00:4511:A684:D461:3188 (via AS12353: VODAFONE-PT from , , PT) using a 128-bit SSL HTTP/2.0 IPv6 connection.
Navigation
Index
Login
About Me (Dan)
BGP Lookup Tool
Blog (Tech Hints & Tips)
DNS Blacklists (dnsbl)
Domains For Sale
Donations
Filter List Generator
IP Information Tool
IP Subnet Calculator
Password Tool
TOR Node List
This page contains a full TOR nodelist (updated at Tue Nov 9 12:32:24 GMT 2021) in the format below.
There are tags of __BEGIN_TOR_NODE_LIST__ and __END_TOR_NODE_LIST__ for easy scripting use of this page.
You can also fetch https://www.dan.me.uk/torlist/ (FULL) or https://www.dan.me.uk/torlist/?exit (EXIT only) for a list of ips only, one per line - updated every 30 minutes. Ideal for constructing your own tor banlists.
NOTE: This is a FULL list including more than just exit nodes. If you only wish to block exit nodes you NEED to process the list to include only flags E and/or X!
You WILL upset people if you block the full list as many nodes do not permit exit.
<ip>|<name>|<router-port>|<directory-port>|<flags>|<uptime>|<version>|<contactinfo>
Total number of nodes is: 8358
1.123.197.30|KarnMidRelay|9001|0|FRDV|1580476|Tor 0.3.5.15|karntor@protonmail.com
1.33.83.1|fwioetwg4utghw4ignc|443|80|FHRSDV|394384|Tor 0.3.5.16|
100.14.159.254|throughhere|9001|9030|FGRSDV|194500|Tor 0.4.5.5-rc|jim(dot)r(at)outlook(dot)com
100.14.23.208|Unnamed|443|0|FHRSDV|3869687|Tor 0.3.5.15|7wteh7hf7bvtu2t
100.36.135.212|anothermiddlefinger|6001|9030|RSDV|906067|Tor 0.4.5.10|Random Person <me@me.net>
101.100.146.147|ExplorationRelay|443|80|EFGHRSDV|4068874|Tor 0.4.4.6|Random Person outofluck at gmail dot com
101.100.160.122|Dzeroth|9004|0|FGHRSDV|7380282|Tor 0.4.2.7|alexcavazos67@gmail.com

Tor Bridge

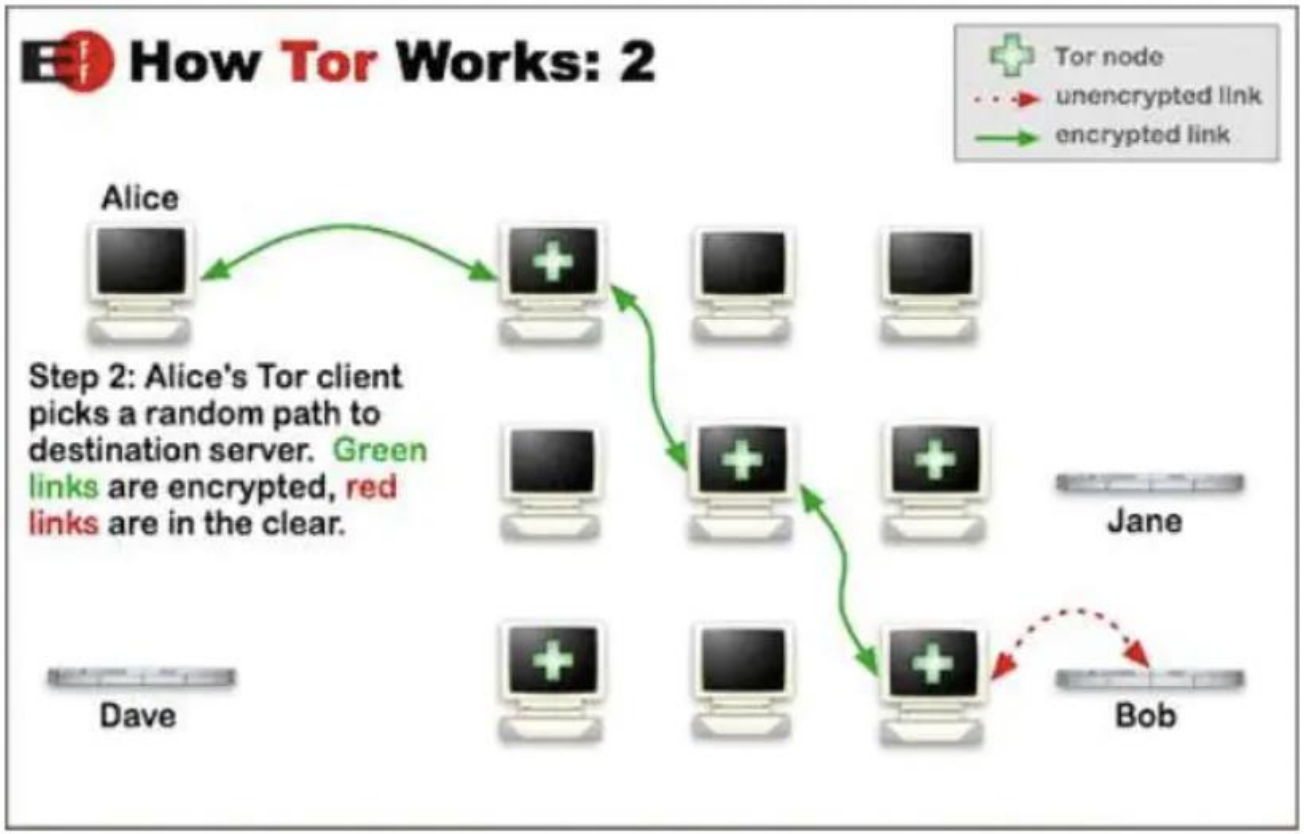
- IP address is not public
- One way to get bridges is to send an email to bridges@torproject.org.



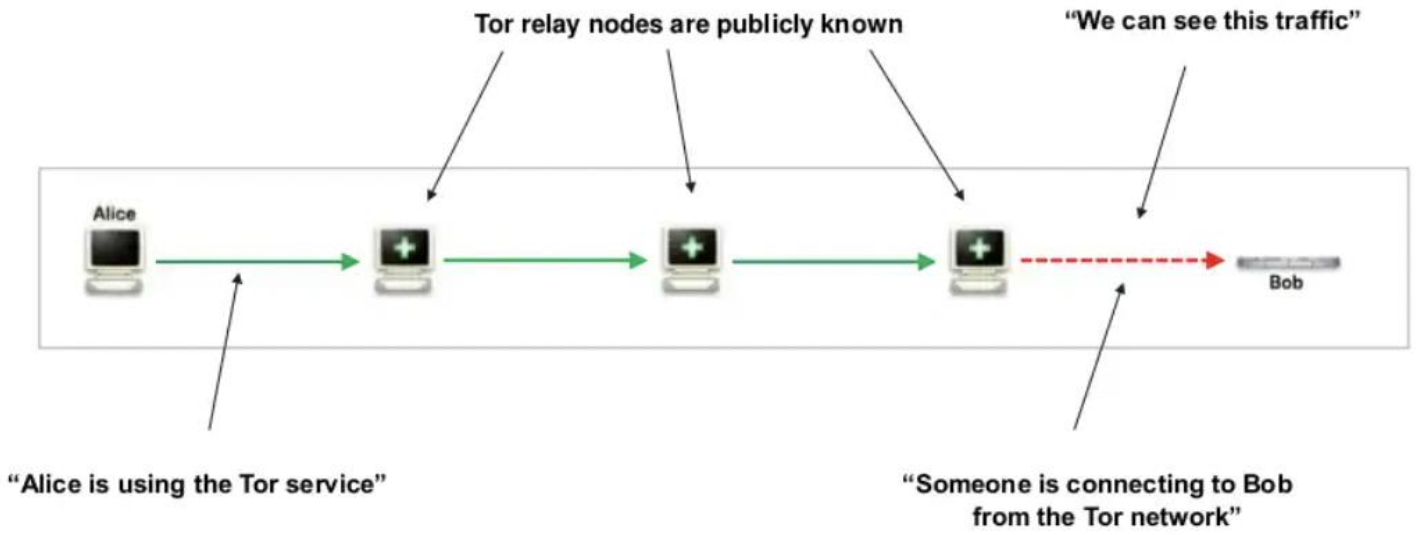
TOR


How Tor Works: 1
Tor node
unencrypted link
encrypted link
Alice
Step 1: Alice's Tor client obtains a list of Tor nodes from a directory server.
Jane
Dave
Bob

TOR


How Tor Works: 2
Tor node
unencrypted link
encrypted link
Alice
Step 2: Alice's Tor client picks a random path to destination server. Green links are encrypted, red links are in the clear.
Jane
Dave
Bob

How anonymous?



EFF

https://www.eff.org/pages/tor-and-https

http

https (TLS) -> Data Confidentiality

tor -> Anonymity

Who owns the Tor nodes?

Volunteers.



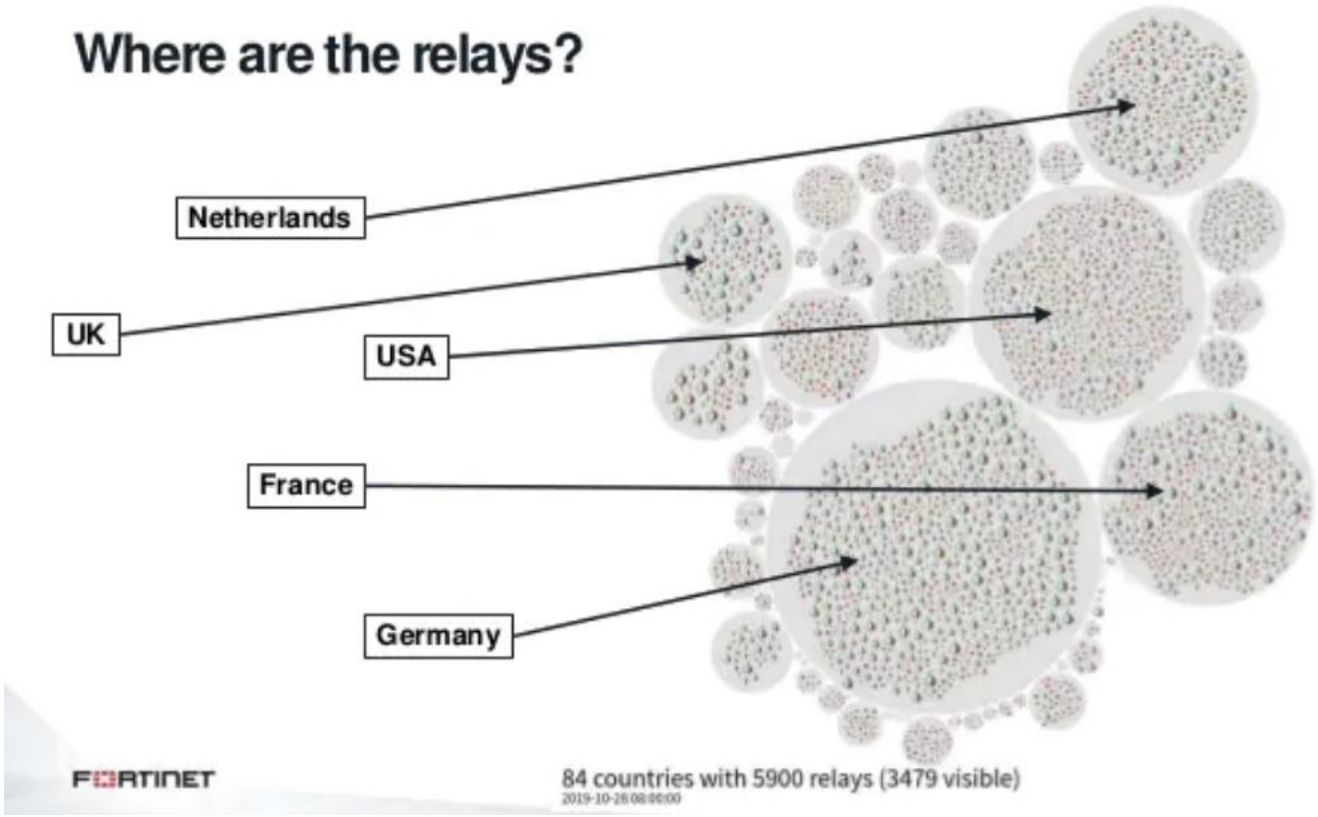
Often universities and other institutions

Most people host Relay or Guard (Entry) nodes

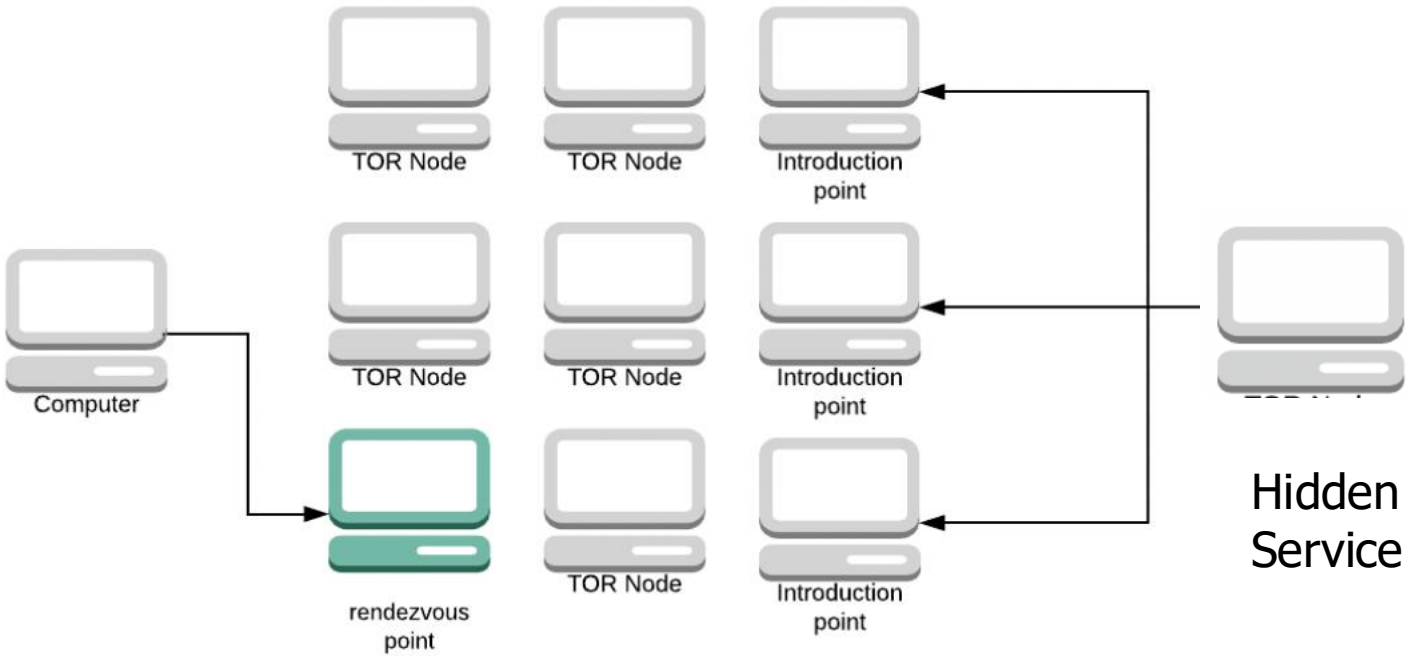
Nodes cannot become guards unless they are stable, and have at least 2Mbytes/s bandwidth

Running an Exit node opens up the potential of receiving abuse complaints

Exit nodes are often blocked by providers or website owners


Where are the relays?
Netherlands
UK
USA
France
Germany
FORTINET
84 countries with 5900 relays (3479 visible)
2019-10-28 08:00:00

Tor Hidden Services





Blockchain

Blockchain – ingredients

- Asymmetric encryption
- Hash functions

What is Blockchain?

- Distributed system
- Uses cryptographic mechanisms
- Implement ledgers (livros de registo / livros razão)
- Initially known because of Bitcoin

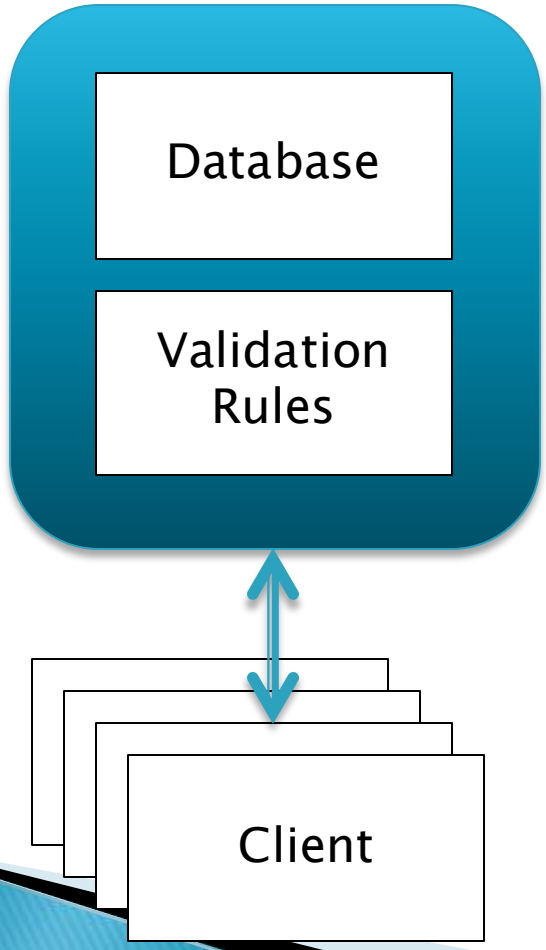
When used?

- Needed to implement a distributed “database” of transactions
- Needed by multiple entities
- Without mutual trust
- Without the intermediation of third parties

History....

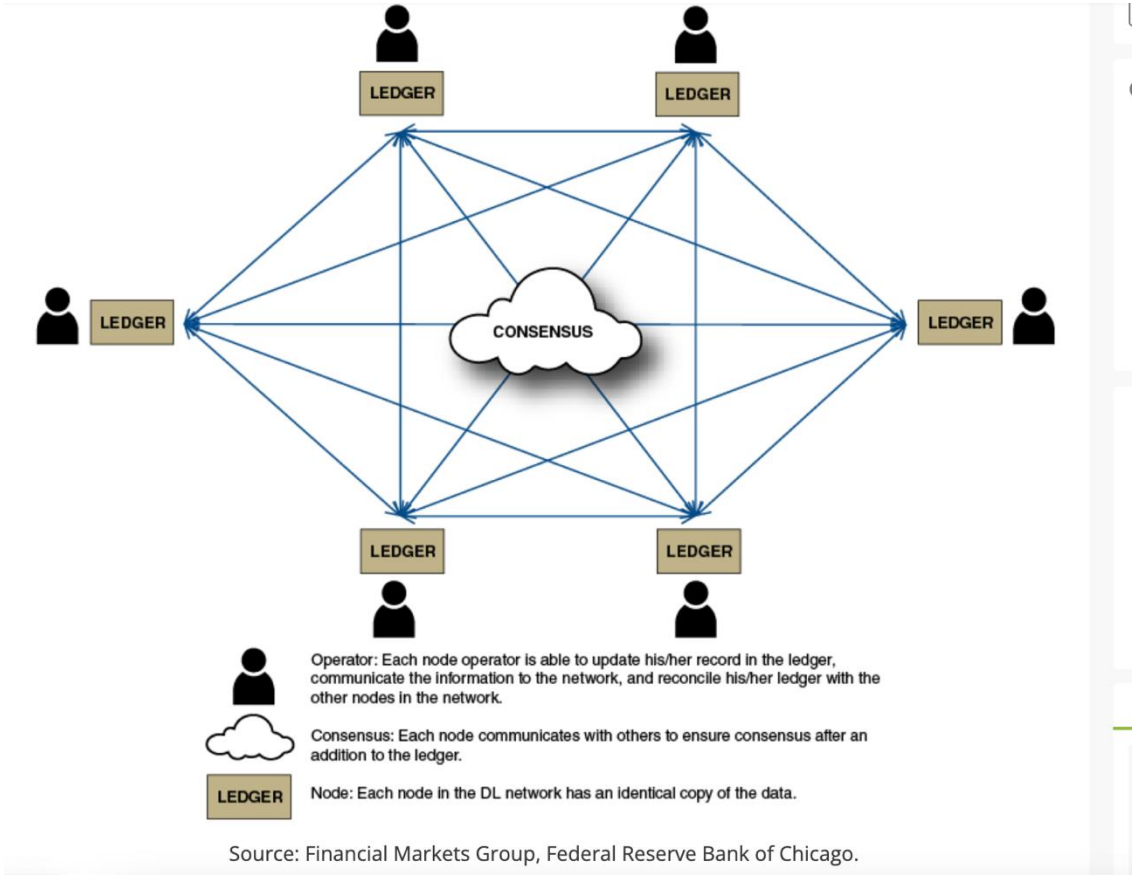
- Blockchain is not Bitcoin
- Satoshi Nakamoto (pseudonym) and his/their creation, Bitcoin, popularized Blockchain technology. (There are currently arguments that Bitcoin was not the first blockchain.)
- On October 31, 2008, *Satoshi Nakamoto* released the Bitcoin White Paper outlining a purely peer to peer electronic cash/digital asset transfer system. This is the first popular implementation of Blockchain and is attributed as birthing today's Blockchain industry.
- Since then, additional Blockchains have been popularized, Ethereum, various Hyperledger project solutions, as well as numerous others including "Blockchain like" solutions such as *GuardTime's KSI* products
- Today there are various *flavors* of Blockchain.

Traditional approach



- Centralized ledger
- Controlled by an authority
- Access protected writes to an authoritative database
- Transactions, time stamping, contracts, etc.

Blockchain approach



Source: Financial Markets Group, Federal Reserve Bank of Chicago.

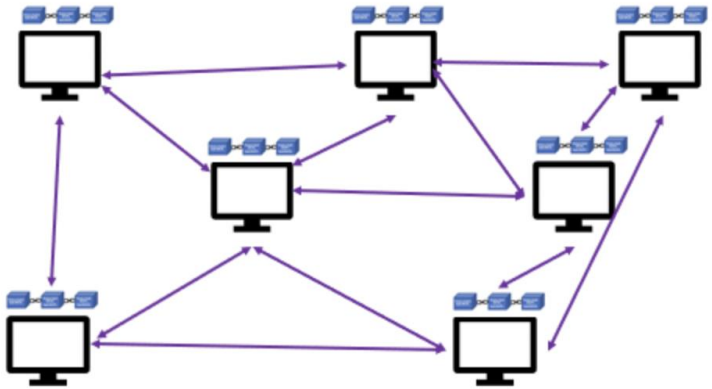
- Public ledger
- You can insert, select data, but **can't** update or delete data
- Based on **p2p** (peer-to-peer) technology, cryptology
- Operator / Miner
- Each transaction can be identified by the sender's public keys

Blockchain properties

- Decentralisation — no single party has control over what information goes in
- Consensus — many different parties store exact copies of the same ledger, so the majority has to agree on the information being added
- ‘Add-only’, meaning you can’t edit what’s already there, you can only add information
- New information can’t conflict with what’s already been added
- Information is able to be accessed and replicated by everybody on the network

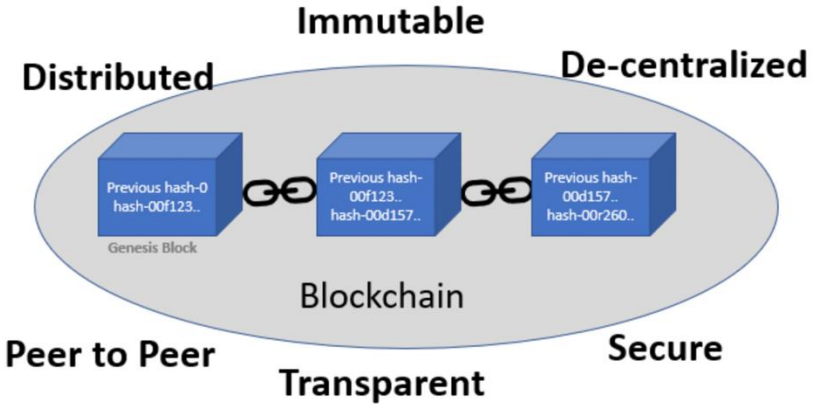
Miners

- Mining is the process by which new transactions are entered into circulation;
- It is also the way that new transactions are confirmed by the network and a critical component of the maintenance and development of the blockchain ledger.
- "Mining" is performed using sophisticated hardware that solves an extremely complex computational math problem.

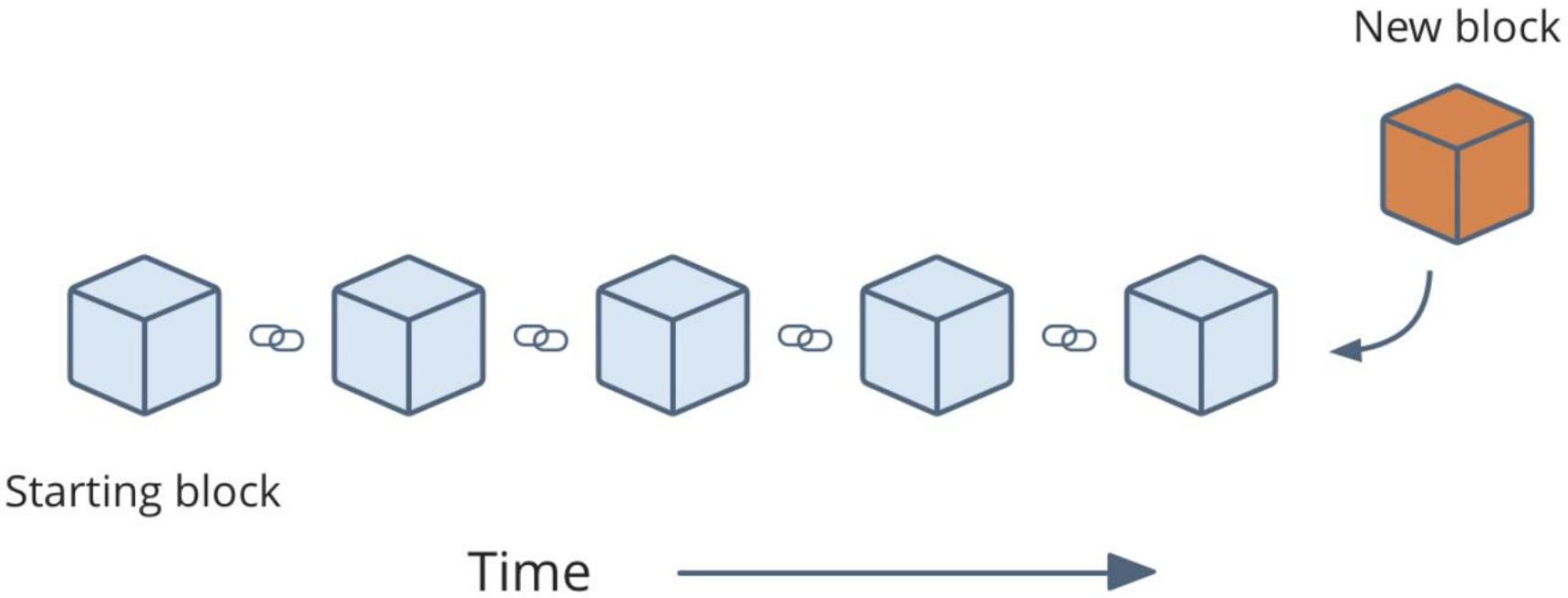


Ledger (livro razão)

- It is a series (or chain) of blocks on which transaction details are recorded after suitable authentication and verification by the designated network participants.
- A distributed ledger is decentralized to eliminate the need for a central authority or intermediary to process, validate or authenticate transactions.
- Timely ordered
- All files in the distributed ledger are then timestamped and given a unique cryptographic signature.
- All of the participants on the distributed ledger can view all of the records in question.

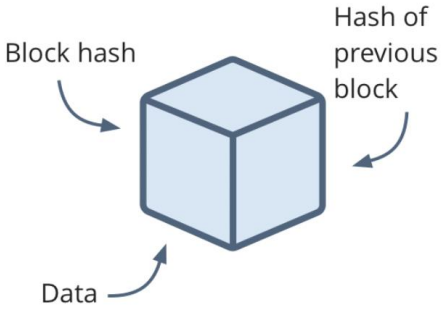


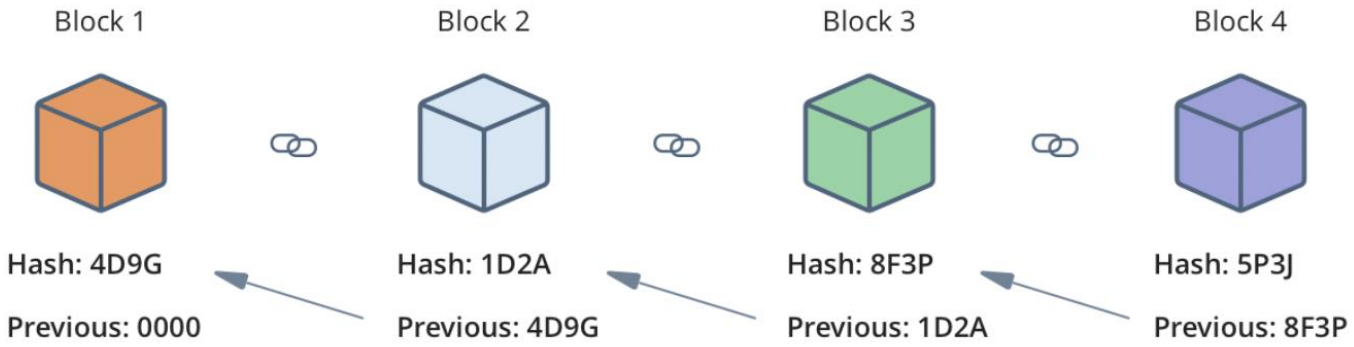
Ledger – linear chain of blocks



Block

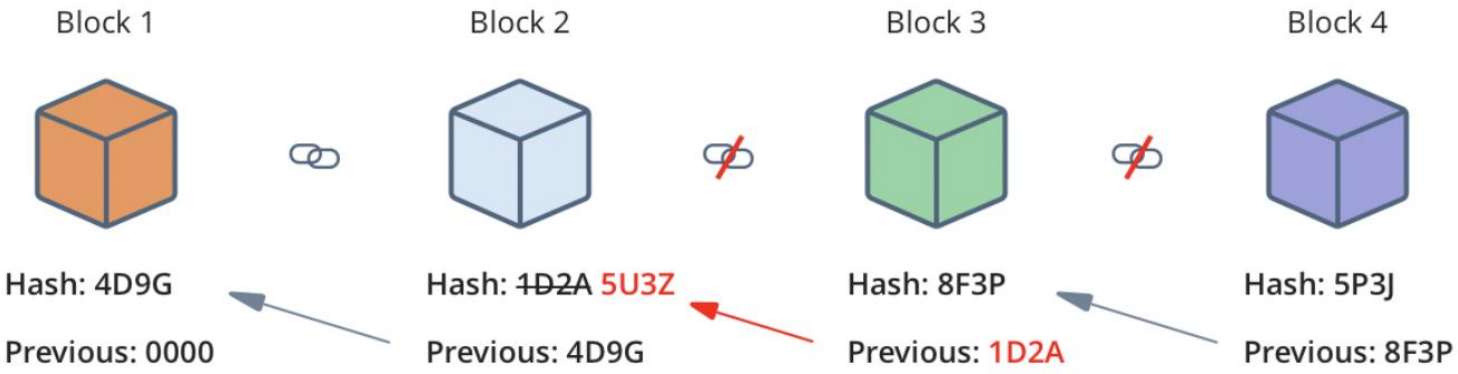
- Data on transactions
- The block's hash
- The hash of the previous block





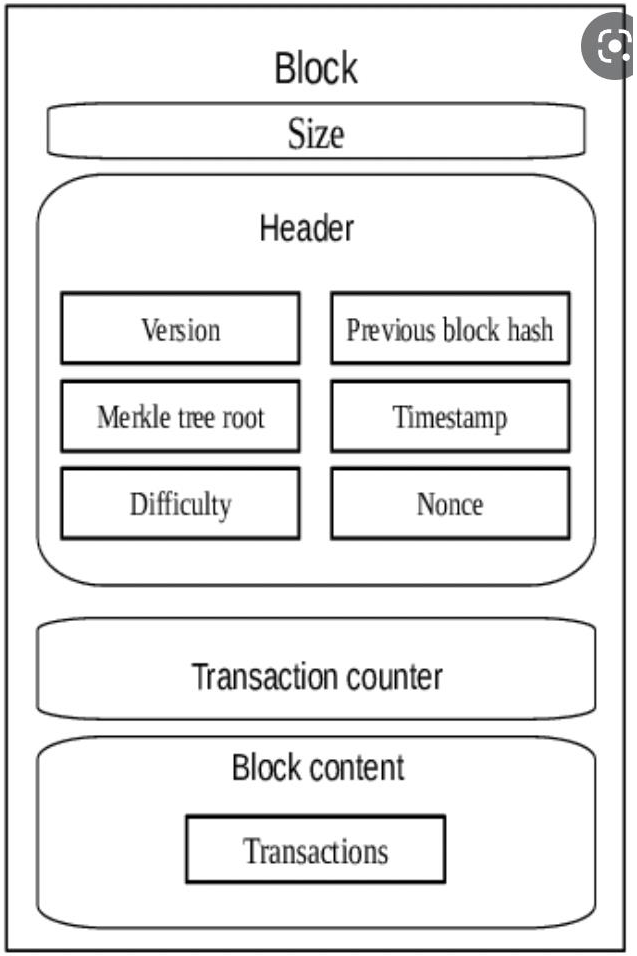
Block tamper

- when block 2 is changed



- The ledger exists on thousands of computers all over the world, so to fake that transaction, we'd need to somehow get access to over 50% of the computers, and repeat the mining process for all the ledgers we control.

Block structure



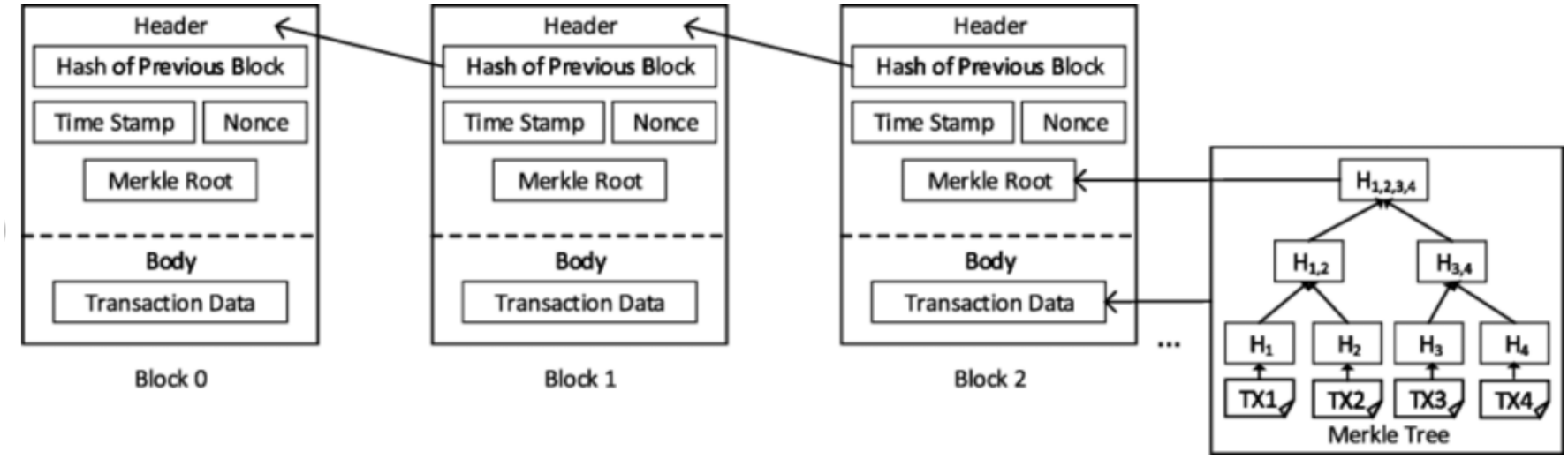
Block structure

- **Magic number**: This 4-byte field indicates the file format
- **Blocksize**: This 4-byte field sets a cap on the amount of data that can be contained in a block. The Bitcoin block size is limited to one megabyte.
- **Block header**: This 80-byte field consists of six individual components.
- **Transaction counter**: This field can range in size from one to nine bytes and is a positive integer that represents the number of transactions contained in the block.
- **Transactions**: This variable size field contains the list of all transactions contained in the block and is typically filled with enough transactions to fill the 1MB Bitcoin block size limit.

Block structure – header

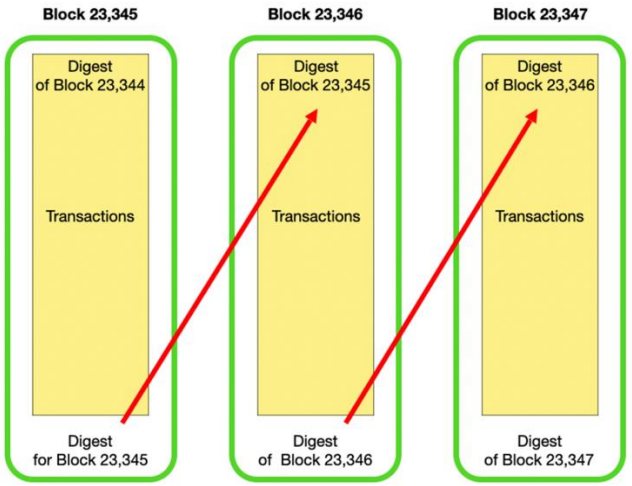
- **Version**: This 4-byte field indicates the version number of the protocol being used."
- **hashPrevBlock**: This 32-byte field contains a 256-bit hash of the previous block header.
- **hashMerkleRoot**: This 32-byte field contains a 256-bit hash of the root of the Merkle tree of all the transactions in the current block.
- **Time**: This 4-byte field contains a timestamp of the current block that is used to situate it chronologically in the blockchain.
- **Difficulty**: This 4-byte field contains the target difficulty of the current block which determines how difficult the target hash will be to find.
- **Nonce**: This 4-byte field contains a 32-bit number that a miner must alter in order to correctly solve the computational puzzle for the current block.

Merkle Hash

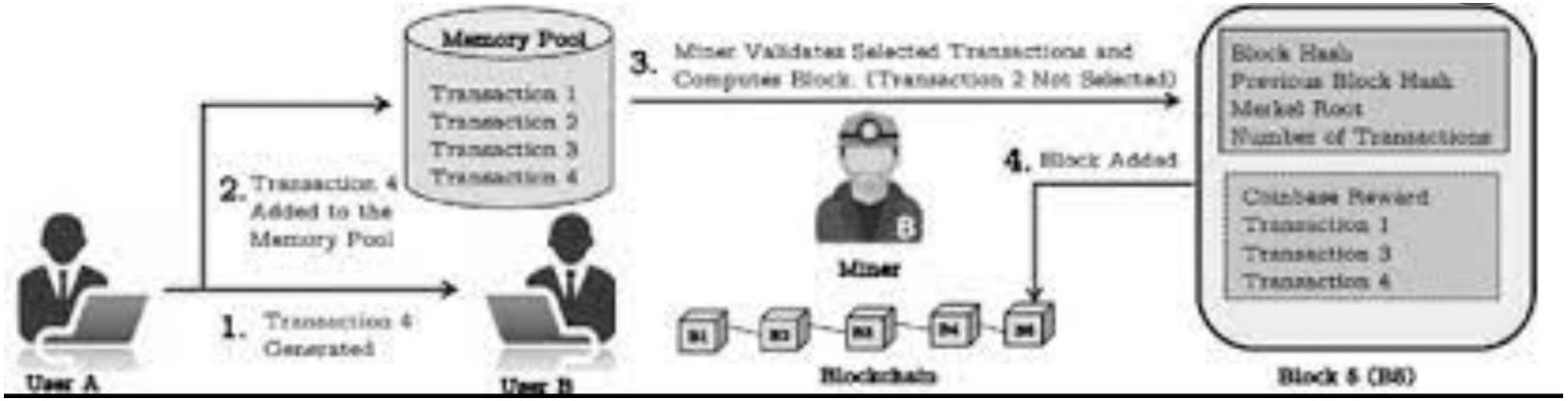

Header
Hash of Previous Block
Time Stamp
Nonce
Merkle Root
Body
Transaction Data
Block 0
Header
Hash of Previous Block
Time Stamp
Nonce
Merkle Root
Body
Transaction Data
Block 1
Header
Hash of Previous Block
Time Stamp
Nonce
Merkle Root
Body
Transaction Data
Block 2
...
$H_{1,2,3,4}$
$H_{1,2}$
$H_{3,4}$
H_1
H_2
H_3
H_4
TX1
TX2
TX3
TX4
Merkle Tree

Ledger confidence

- Use of public keys and digital signatures to guarantee the authenticity of each transaction.
- Each user uses his public key to authenticate the transaction
- Transactions that make up the body of each block are protected by a hash code included in the block header.
- Each block integrated in the linear chain is linked to the previous block by a hash code (SHA-256). Changing a block without impacting this hash code, or changing the hash code of all blocks in the chain is computationally infeasible.
- Several users keep copies of the total ledger. A consensus mechanism ensures that all blockchain records are consistent.



Solving a bock (criação do bloco)
Memory pool

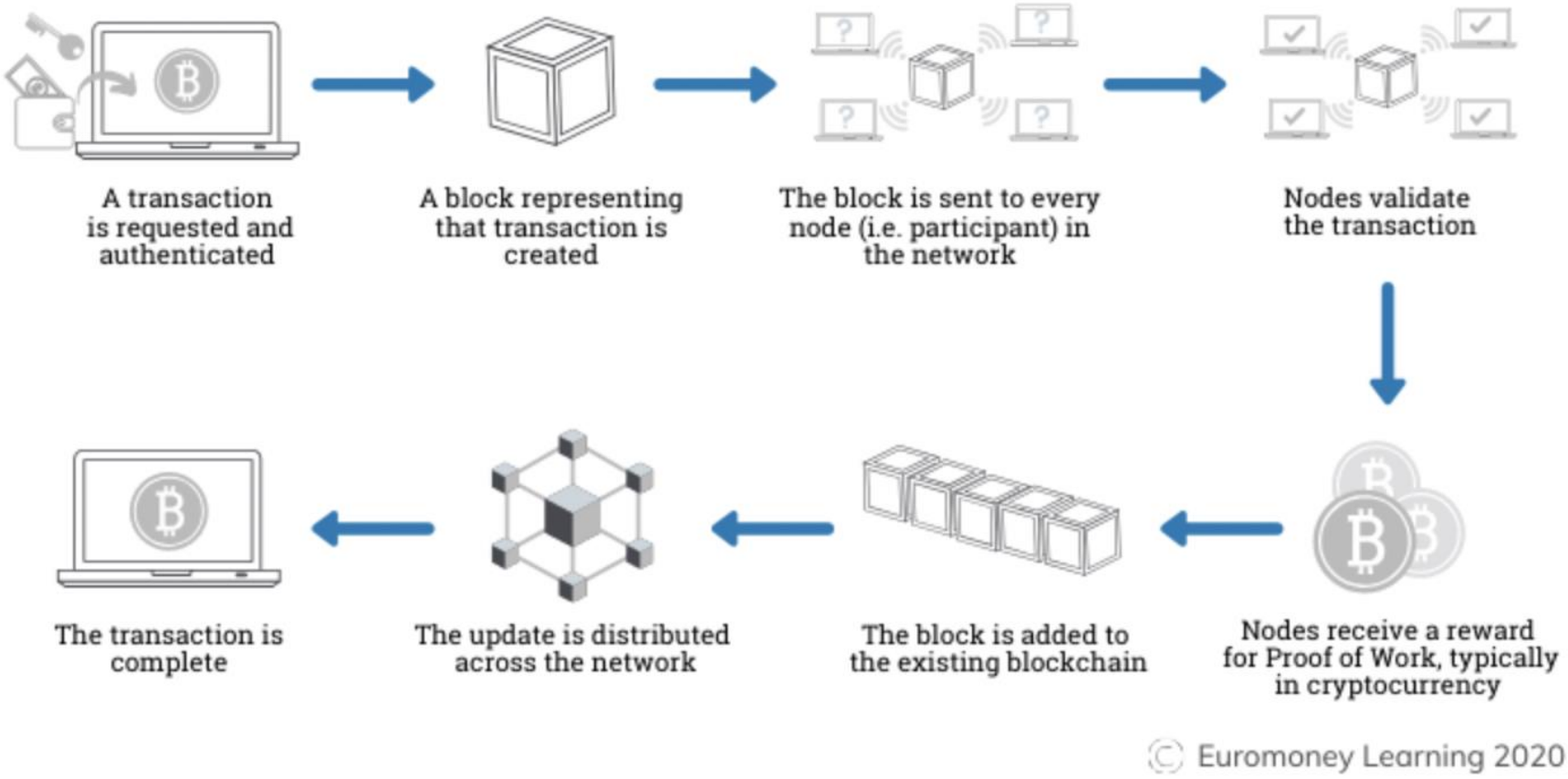


The Nonce / Hash Loop

- The algorithm to make a new block:

1. Verify the hashes of all the previous blocks
2. Build a new block with a random nonce
3. Hash the new block. Does it have N zeros?
   - No? Go back to Step 2
   - Yes? Send your new block to everyone!

Solving a bock (criação do bloco)



Forks

- A Fork is a blockchain split that produces two competing branches.
- Can be **accidental** or **intentional**.
- Intentional forks are further categorized as either **soft forks** or **hard forks**.
- Accidental forks are resolved by the blockchain.
- Intentional forks are used to implement new consensus rules.
- **Hard forks** require nodes to be upgraded to the new consensus rules or to rollback the state.
- **Soft forks** don't require nodes to be upgraded to the new consensus rules. Some cryptocurrencies, like **Bitcoin Cash**, are created using hard forks.

Forks

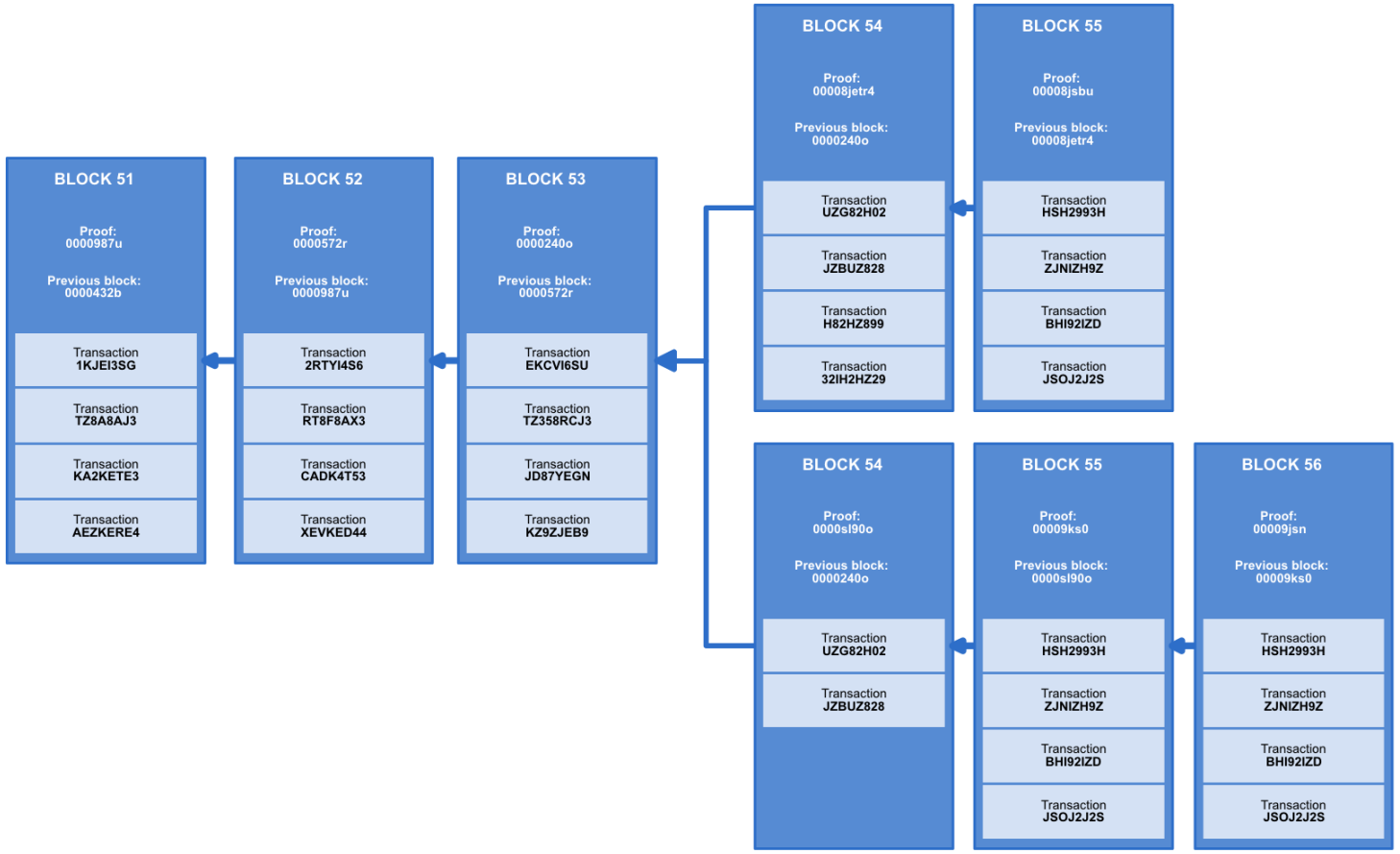


Image source: Scorechain

Accidental forks

- At any given moment, thousands of miners are competing to create a new block.
- With so much mining going on at once, two or more miners sometimes mine a new block at the same time.
- When this happens, an **accidental fork** is created.
- The problem is solved when new blocks are added to one of the chains.
- When that happens, the network continues working on the longer chain and abandons the shorter one.

Intentional forks (hard forks)

- A hard fork is a fork that introduces new rules and requires the nodes in the network to upgrade their software.
- Consider a blockchain with a block size limit of 1 MB. If you wanted larger blocks that could store up to 8 MB of data, you would have to implement a new set of rules that would increase the block size limit from 1 MB to 8 MB.
- When a **hard fork** occurs, the community members (users and miners) must make a decision. They can either update their node and switch to the newly-forked chain, or they can keep running the old software.

Intentional forks (soft forks)

- As opposed to hard forks, changes implemented by **soft forks** make the chains **forward compatible**.
- To be forward compatible, blocks created under new rules must also be valid under the old rules.
- Due to that, a soft fork does not require nodes to be upgraded. They can keep running the old software version and still participate in the upgraded network as validators of transactions.
- Soft forks can be activated by users (**UASF – user activated soft fork**) or miners (**MASF – miner activated soft forks**).

Consense models

- A consensus mechanism is a **fault-tolerant mechanism** that is used in computer and blockchain systems to achieve the necessary agreement on a single data value or a single state of the network among distributed processes or multi-agent systems, such as with blockchain and cryptocurrencies.
- They define the rules that determine which miner publishes the next block in the chain.

Types of blockchain consensus mechanisms

Proof of Work

Proof of Work mechanim involves miners who solve complicated mathematical puzzles to produce a new block.

Proof of Stake

Proof of Stake uses a randomized process to figure out who gets a chance to produce the next block.

Delegated Proof of Stake

In Delegated Proof of Stake process, users can stake their coins and vote for a particular number of delegates to create a new block.

Proof of Capacity

Proof of Capacity method stores solutions of complex mathematical puzzles in digital storages such as hard disks that are used to create new blocks.

Proof of Elapsed Time

Proof of Elapsed Time process randomly and fairly decides the producer of a new block based on their waiting time.

Proof of Identity

Proof of Identity is a cryptographic evidence for a user's private key that is cryptographically attached to a specific transaction.

Proof of Authority

In Proof of Authority mechanism, the identities of validators in the network are at stake.

Proof of Activity

Proof of Activity mechanism is a hybrid of Proof of Work and Proof of Stake.

Block chains

- Public
- Private

Blockchain limitations

- Resources used
- Dead of blockchain

Attacking the Blockchain Network



- Denial of Service Attacks
  - An attacker can create a large number of spam transactions and transmit them to the network (similar to a DoS attack on a webserver).
- Eclipse/Routing Attacks
  - The network is split up into two or more isolated groups. Both attacks can be used to facilitate a double-spend attack (by sending a different transaction to each isolated individual/group) or a 51% attack (by filtering the victim's view of the network state so that they mine a version of history that's in the attacker's favor)



Questions?